TECHNICAL DETAIL

Title	Broken Access Control: Unauthorized Information Disclosure on Product Catalogue Page
Reporter	Daffa Rahadya Atmawiguna (rahadya.daffaa@gmail.com)
Date	2025-12-28
Affected Asset	https://bertani.my.id/catalogue/
Severity	**Medium**
CVSS Score	5.3 CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:L/A:N
Proof of Concepts	Please see Steps to Reproduce section

SUMMARY

Ditemukan kerentanan Broken Access Control pada platform bertani.my.id yang menyebabkan kebocoran informasi inventaris bisnis kepada publik. Melalui pemindaian direktori, ditemukan bahwa halaman katalog produk dapat diakses secara langsung tanpa proses login. Meskipun fungsi untuk menambah atau memodifikasi data (tombol "+Tambah") tetap terlindungi oleh validasi di sisi server, pengguna anonim tetap dapat melihat rincian produk, jumlah stok, dan strategi harga yang seharusnya bersifat rahasia bagi pihak internal perusahaan.

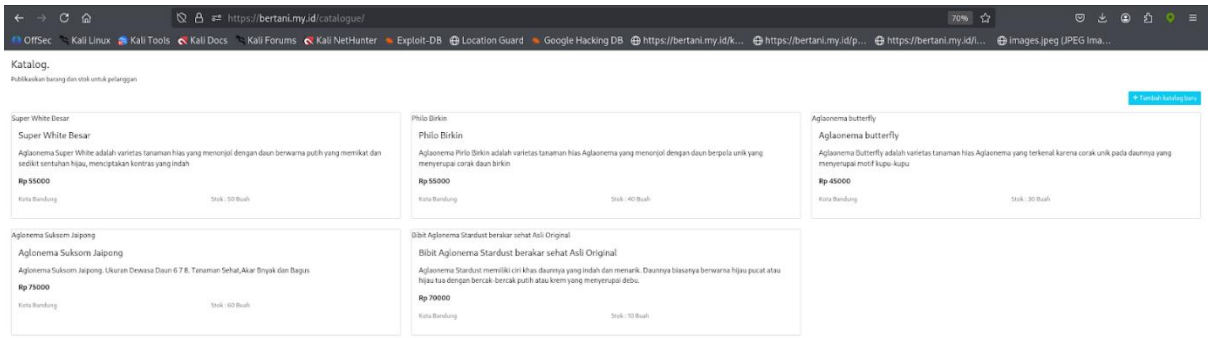
STEPS TO REPRODUCE

1. jalankan command gobuster dir -u https://bertani.my.id -w /usr/share/wordlists/dirbuster/directory-list-2.3-medium.txt -s "200,204,301,302,307,403" -b ""

```
┌──(nectar㉿nectar)-[~]
└─$ gobuster dir -u https://bertani.my.id -w /usr/share/wordlists/dirbuster/directory-list-2.3-medium.txt -s "200,204,301,302,307,403" -b ""
===============================================================
Gobuster v3.8
by OJ Reeves (@TheColonial) & Christian Mehlmauer (@firefart)
===============================================================
[+] Url:            https://bertani.my.id
[+] Method:         GET
[+] Threads:        10
[+] Wordlist:       /usr/share/wordlists/dirbuster/directory-list-2.3-medium.txt
[+] Status codes:   200,204,301,302,307,403
[+] User Agent:     gobuster/3.8
[+] Timeout:        10s
===============================================================
Starting gobuster in directory enumeration mode
===============================================================
/home                 (Status: 302) [Size: 354] [--> https://bertani.my.id/login]
/login                (Status: 200) [Size: 8379]
/register             (Status: 200) [Size: 10742]
/forum                (Status: 302) [Size: 354] [--> https://bertani.my.id/login]
/user                 (Status: 302) [Size: 354] [--> https://bertani.my.id/login]
/video                (Status: 302) [Size: 354] [--> https://bertani.my.id/login]
/users                (Status: 302) [Size: 354] [--> https://bertani.my.id/login]
/shop                 (Status: 302) [Size: 354] [--> https://bertani.my.id/login]
/photo                (Status: 302) [Size: 354] [--> https://bertani.my.id/login]
/storage              (Status: 301) [Size: 178] [--> https://bertani.my.id/storage/]
/css                  (Status: 301) [Size: 178] [--> https://bertani.my.id/css/]
/message              (Status: 302) [Size: 354] [--> https://bertani.my.id/login]
/request              (Status: 302) [Size: 354] [--> https://bertani.my.id/login]
/catalogue            (Status: 200) [Size: 8764]
/knowledge            (Status: 302) [Size: 354] [--> https://bertani.my.id/login]
/transactions         (Status: 200) [Size: 4361]
/prediction           (Status: 302) [Size: 354] [--> https://bertani.my.id/login]
Progress: 220558 / 220558 (100.00%)
===============================================================
Finished
===============================================================
```

2. Dari informasi tersebut kita bisa melihat kita dapat masuk ke url catalogue tanpa harus login

3. Tampilan saat masuk ke url https://beratani.my.id/catalogue/ tanpa haus login



EXPECTED RESULT

Seharusnya, akses ke URL /catalogue/ dilindungi oleh *middleware* autentikasi. Pengguna yang belum login seharusnya diarahkan kembali ke halaman /login (Status 302) atau ditolak aksesnya (Status 403).

ACTUAL RESULT

1. Halaman /catalogue/ dapat dibuka sepenuhnya oleh pengguna anonim dengan respons HTTP 200 OK.
2. Pengguna tidak berwenang dapat melihat daftar seluruh produk, harga jual, dan sisa stok di gudang.
3. Catatan Teknis: Fungsi operasional untuk menambah data produk (*write access*) tidak dapat dieksekusi karena adanya proteksi *middleware* pada metode pengiriman data di *backend*, namun rute tampilan (*view*) tetap terbuka

IMPACT

1. Information Disclosure: Kebocoran data inventaris, stok, dan strategi harga kepada kompetitor atau pihak luar yang dapat merugikan bisnis.
2. Security Inconsistency: Menunjukkan adanya ketidakkonsistenan dalam penerapan kebijakan keamanan di seluruh rute aplikasi, yang dapat menjadi celah bagi serangan pengumpulan informasi lanjutan (*reconnaissance*).

RECOMMENDATION

1. Daftarkan Middleware: Masukkan rute tampilan /catalogue ke dalam grup *middleware* auth untuk memastikan hanya pengguna terverifikasi yang bisa melihat halaman tersebut.
2. Audit Menyeluruh: Lakukan audit pada seluruh rute yang ditemukan oleh Gobuster untuk memastikan tidak ada rute manajerial atau informatif lainnya yang terekspos tanpa proteksi.

REFERENCES

- OWASP Top 10 - A01:2021 Broken Access Control: https://owasp.org/Top10/A01_2021-Broken_Access_Control/
- CWE-284: Improper Access Control: https://cwe.mitre.org/data/definitions/284.html